

Lección 01 - Cyber Kill Chain y controles de seguridad

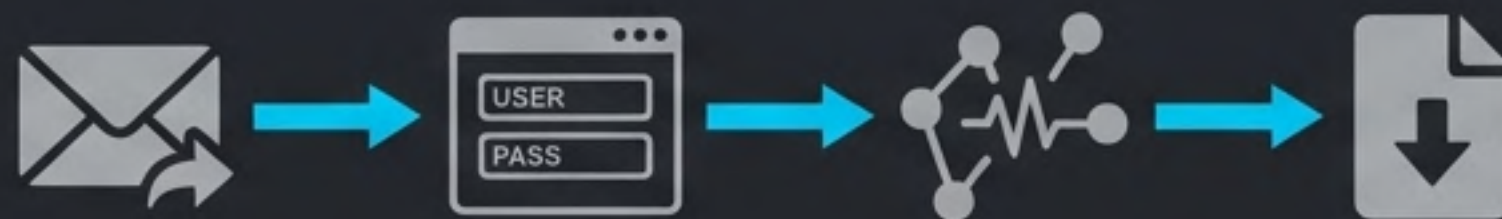


Reconstruyendo una intrusión para encontrar puntos clave de defensa.

Hechos aislados



Una historia comprensible



Un incidente suele presentarse como eventos desordenados. La cadena de ataque los organiza para responder: ¿Qué preparó? ¿Cómo llegó? ¿Cómo avanzó? ¿Qué buscaba?

El valor defensivo: No tienes que esperar al daño final. Permite intervenir, prevenir o detectar la amenaza **en múltiples puntos** antes de que logre su objetivo.



Riesgo = posibilidad de que una amenaza aproveche una vulnerabilidad y produzca daño.

Activo

Recurso de valor.

Ej: Cuenta de Finanzas,
base de clientes

Amenaza

Quien intenta causar
daño.

Ej: Atacante externo

Vulnerabilidad

Condición habilitante.

Ej: Proceso débil para
verificar facturas

Ataque

Acciones para
aprovechar debilidades.

Ej: Phishing + robo de
credenciales

Consecuencia

Resultado negativo de
un ataque.

Ej: Exposición de datos.

Riesgo

Posibilidad de que una
amenaza afecte un activo
y produzca daño.

Ej: Posibilidad de acceso
indebido y exposición de datos.

Control

Medida que
modifica el
riesgo.

Evidencia

Prueba de que el control funciona.

Ej: Log de bloqueo

Las 7 Fases de la Cyber Kill Chain



Regla mnemotécnica: Busca → prepara → entrega → aprovecha → se instala → se comunica → actúa.

1. Reconocimiento y 2. Armamentización

1. Reconocimiento	
¿Qué ocurre?	→ El adversario busca información.
Caso Bahía:	→ Recopila nombres y cargos públicos.
Defensa: →	Control: Reducir exposición. Evidencia: Revisión de huella digital. Señal posible: exposición pública, consultas o escaneos observables, si existen fuentes para detectarlos.

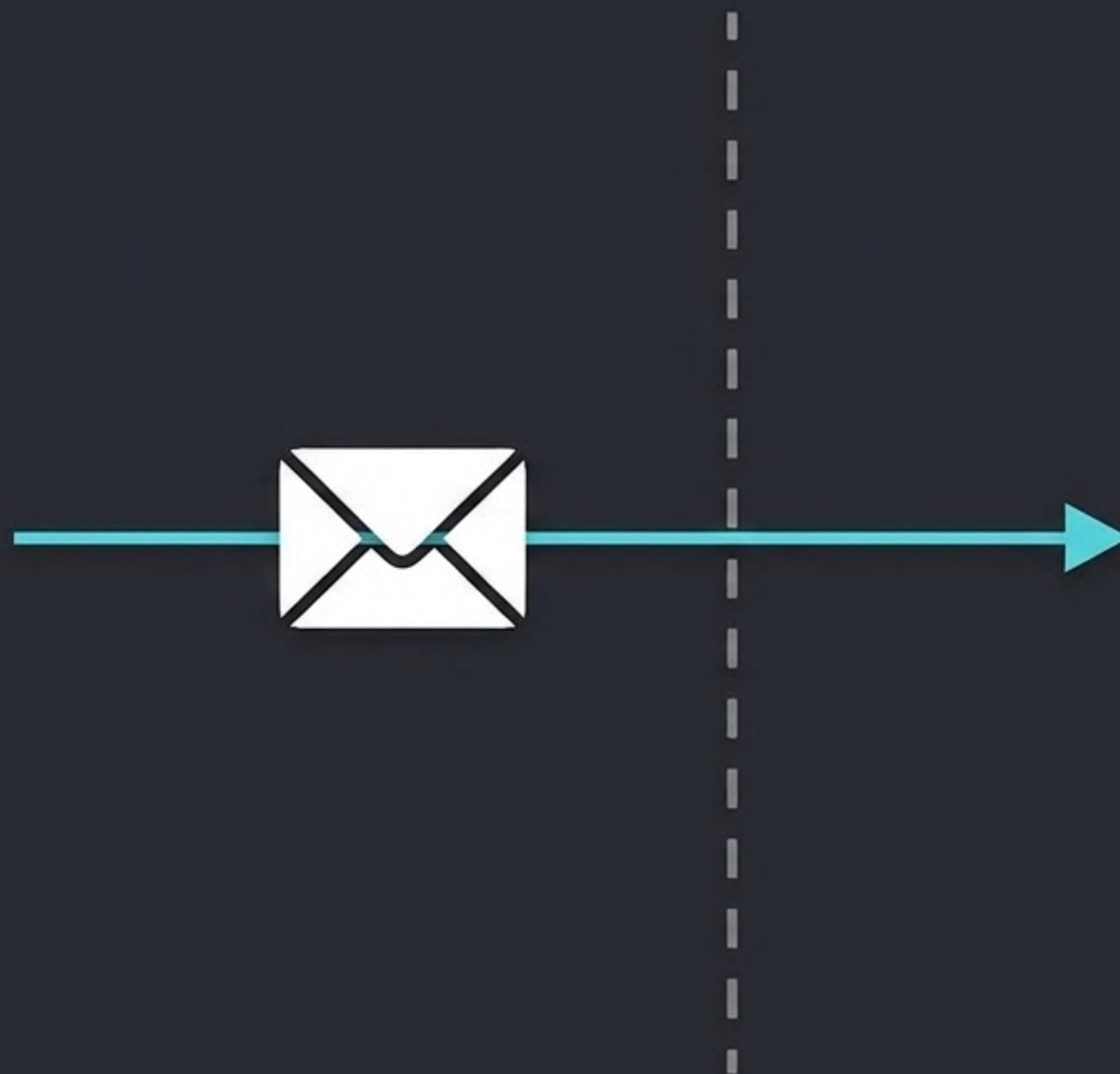
2. Armamentización	
¿Qué ocurre?	→ Prepara recursos o infraestructura.
Caso Bahía:	→ Registra dominio falso parecido al proveedor.
Defensa: →	Control: monitoreo de dominios similares y suplantación de marca. Evidencia: Alerta de suplantación. Señal: Nuevo dominio similar.



Gran parte de estas fases ocurre fuera de los sistemas de la víctima, limitando nuestra visibilidad.

3. Entrega

Análisis Card	
Pregunta clave:	¿Cómo llega el recurso al objetivo? (correo, web, USB, etc.).
Hecho en el caso:	Envía factura urgente al área de Finanzas.
Señal posible:	Mensaje, enlace o archivo inesperado.
Defensa sugerida:	Control: Filtro de correo (Secure Email Gateway). Evidencia: Logs que demuestran si el correo fue bloqueado o permitido.



4. Explotación (Más allá del software)

Análisis Card	
Pregunta clave:	¿Qué debilidad o interacción le permite avanzar?
Hecho en el caso:	La página falsa captura las credenciales del usuario.
Señal posible:	Autenticación desde contexto inusual tras un correo.
Defensa sugerida:	Control: Autenticación multifactor (MFA), idealmente resistente a phishing. y Filtrado Web. Evidencia: Logs de desafío MFA, registro de accesos denegados.



Aclaración: No siempre implica un exploit técnico. Una interacción humana, el robo de credenciales o una vulnerabilidad técnica pueden permitir que el atacante avance.

5. Instalación – capacidad para continuar el acceso

Análisis Card	
Pregunta clave:	¿Qué capacidad deja habilitada para seguir actuando?
Hecho en el caso:	Aparece una herramienta de acceso remoto no autorizada.
Señal posible:	Nuevo servicio, tarea programada, o cambio de configuración.
Defensa sugerida:	Control: EDR (Detección y Respuesta en Endpoint), Mínimo Privilegio. Evidencia: Alerta de ejecución bloqueada, revisión de cobertura de agentes.



Aclaración: No siempre significa instalar malware. Puede aparecer una herramienta legítima utilizada indebidamente, una cuenta, un servicio o un cambio de configuración que permita continuar actuando.

6. Comando y Control (C2)

Análisis Card	
Pregunta clave:	¿Cómo mantiene la comunicación o dirige la capacidad?
Hecho en el caso:	La herramienta remota y la sesión podrían proporcionar un canal para mantener comunicación o acceso.
Señal posible:	Conexión periódica (beaconing), sesión fuera del contexto normal.
Defensa sugerida:	Control: Filtrado de salida, Segmentación de red. Evidencia: Log de conexión de salida bloqueada.



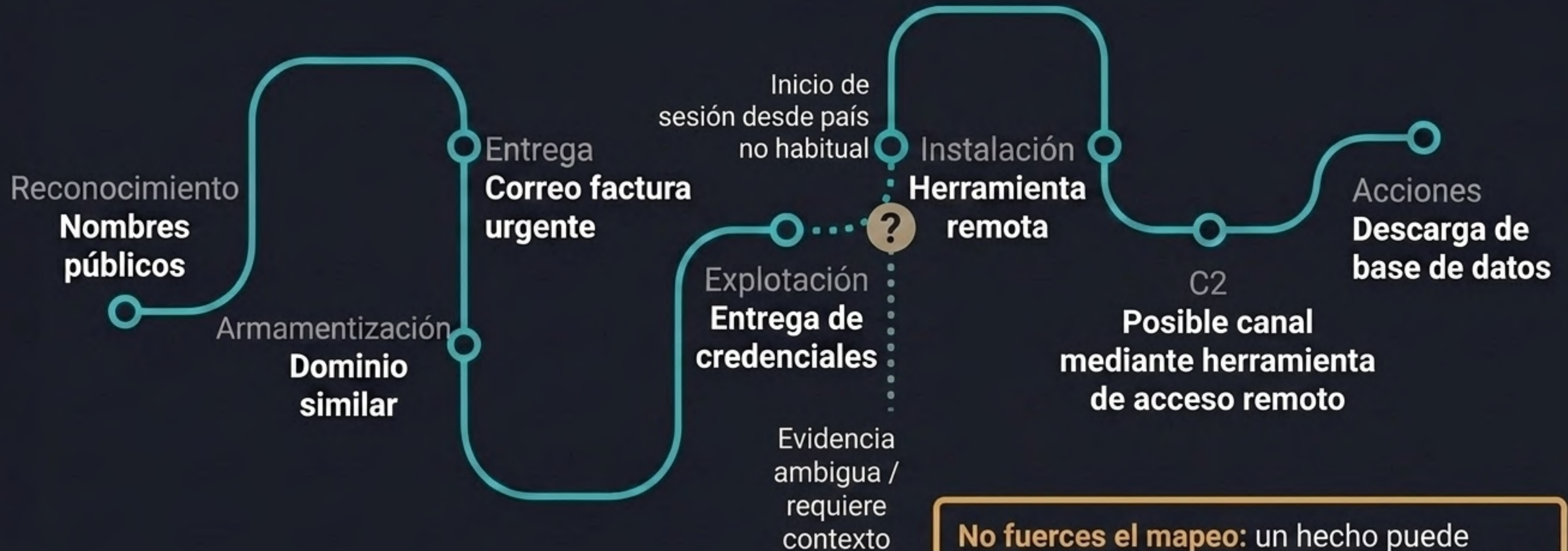
Aclaración: Una sesión anómala no demuestra C2 por sí sola. Se necesita evidencia de cómo se mantiene la comunicación o el control.

7. Acciones sobre los objetivos

Análisis Card	
Pregunta clave:	¿Qué resultado busca finalmente el atacante?
Hecho en el caso:	Descarga de la base de datos de clientes.
Señal posible:	Transferencia masiva, compresión de archivos, acceso a datos sensibles.
Defensa sugerida:	Control: auditoría de accesos, DLP, segmentación y mínimo privilegio. Evidencia: Alerta de volumen inusual extraído, registro de accesos.



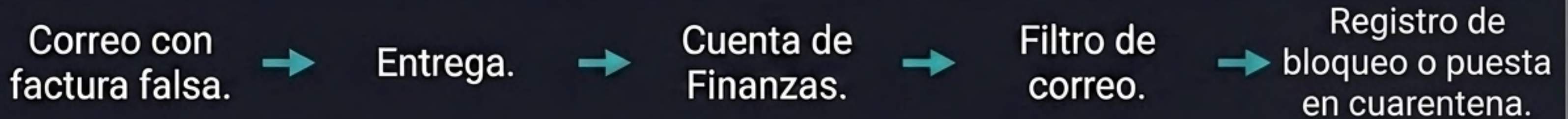
Reconstrucción del caso BAHÍA LOGÍSTICA



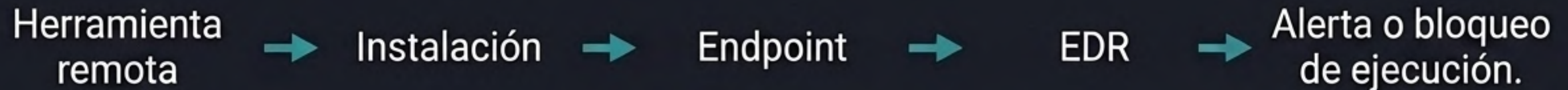
Cómo razonar la defensa: Del Hecho al Control



Ejemplo Completo (Factura)

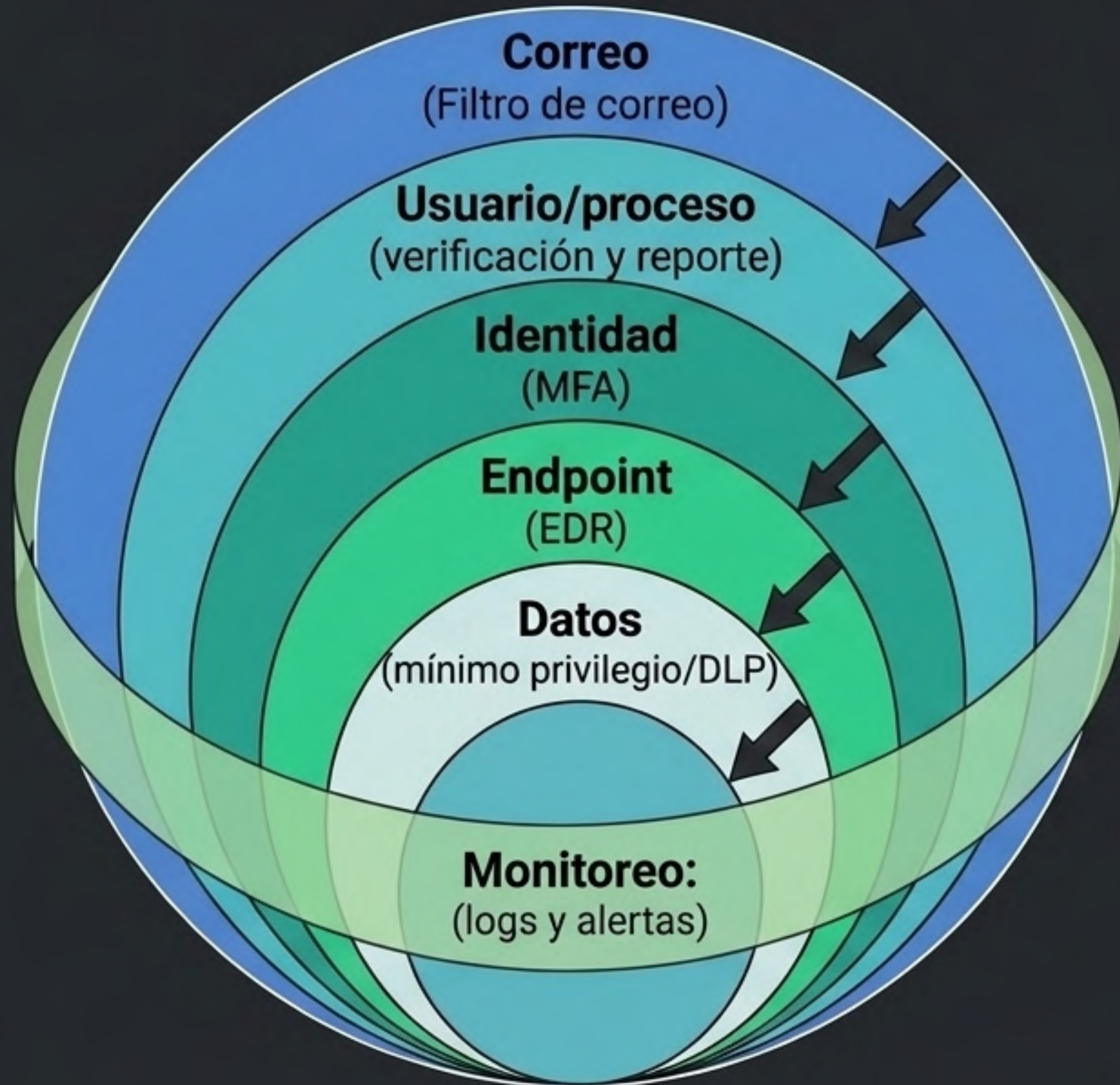


Ejemplo Breve (Herramienta)



Decir “comprar una herramienta de seguridad” no basta: debes indicar qué activo protege, qué intenta prevenir o detectar y cómo comprobarás que funciona.

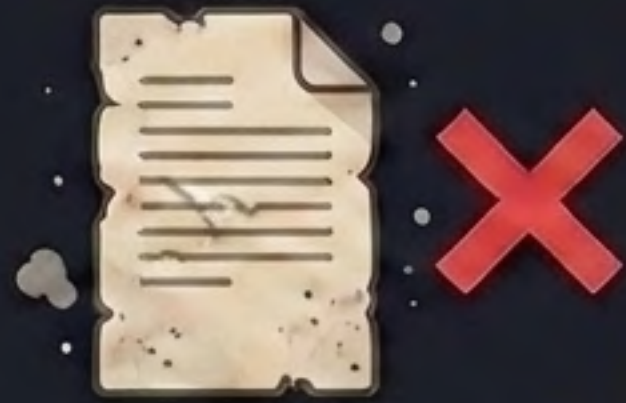
Defensa en Profundidad y Tipos de Controles



Preventivo: intenta impedir una acción o reducir su probabilidad. (Ej: MFA, filtro)	Detectivo: Descubre la actividad (Ej: Alerta EDR)
Correctivo: corrige una condición después de detectarla. (Ej: Revocar acceso)	Recuperación: Restaura el sistema (Ej: Respaldos)

Ningún control es perfecto. La defensa en profundidad combina varias capas para que, si una falla, otras puedan prevenir, detectar o limitar el avance del ataque.

Del papel a la realidad: Evidencia de Funcionamiento



Control Declarado
“Tenemos un firewall.”
(No garantiza efectividad).



Control Verificable
“Log de tráfico malicioso
bloqueado hoy.”

Ejemplos de Evidencia Concreta

Filtro de correo	Log de mensaje en cuarentena.
MFA	Registro de inicio de sesión denegado.
EDR	Consola con agentes activos y alerta de prueba.

Diseño → Implementación → Operación → Efectividad

En esta lección basta asociar cada control con una evidencia concreta y verificable.

Preparación y Límites: Más allá de la Kill Chain

Checklist para tu actividad

- [] Relaciona los hechos con las 7 fases.
- [] Identifica posibles ambigüedades.
- [] Elige 2 puntos de defensa.
- [] Indica qué activo quieres proteger.
- [] Propón 2 controles coherentes para prevenir o detectar el avance.
- [] Relaciona cada propuesta con un hecho concreto.
- [] Explica qué evidencia permitiría verificar que funciona.

Límites

Los ataques reales no siempre son lineales (omiten o repiten fases). Mapear fases no identifica quién es el atacante.

MITRE ATT&CK

Mientras la Kill Chain narra una secuencia general, ATT&CK es un modelo más profundo de comportamientos no secuenciales (Tácticas y Técnicas). Lo usaremos más adelante.